

COMPTE RENDU FINAL DE TP 2.3

Analyse de vulnérabilités avec Nessus et OpenVAS (GVM)

1. Introduction

Dans un contexte où les systèmes informatiques sont de plus en plus exposés aux cyberattaques, la détection des vulnérabilités constitue une étape essentielle de la sécurité informatique.

Ce TP porte sur l'utilisation de deux outils de scan de vulnérabilités :

- Nessus (outil propriétaire)
- OpenVAS / GVM (outil open-source)

L'objectif est d'analyser la sécurité des systèmes Linux et Windows, d'identifier les vulnérabilités, puis de comparer les résultats obtenus.

2. Objectifs du TP

Objectif général :

Mettre en œuvre des scanners de vulnérabilités pour analyser la sécurité d'un système informatique.

Objectifs spécifiques :

- Installer et configurer OpenVAS (GVM)
- Utiliser Nessus pour les scans
- Réaliser des scans sur Linux et Windows
- Identifier les vulnérabilités (CVE)
- Analyser les impacts et risques
- Proposer des corrections
- Comparer les résultats avant/après
- Comparer Nessus et OpenVAS

3. Présentation des outils

3.1 Nessus

Nessus est un scanner de vulnérabilités développé par Tenable.

Fonctionnalités :

- Interface simple et intuitive
- Détection automatique des failles
- Rapports détaillés
- Très utilisé en entreprise

Limite :

- Version complète payante

3.2 OpenVAS (GVM)

OpenVAS est une solution open-source de gestion de vulnérabilités.

Fonctionnalités :

- Gratuit et open-source
- Détection avancée des vulnérabilités
- Utilisation des bases CVE, NVT, SCAP
- Adapté aux environnements professionnels

Limites :

- Installation complexe
- Configuration longue
- Synchronisation des bases lourde

4. Installation et configuration OpenVAS

Installation :

- `sudo apt update && sudo apt upgrade -y`
`sudo apt install gvm -y`

Initialisation :

- `sudo gvm-setup`

Démarrage :

- `sudo gvm-start`

Synchronisation des feeds :

- `sudo greenbone-feed-sync --type GVMDB --DATA`
`sudo greenbone-feed-sync --type SCAP`
`sudo greenbone-feed-sync --type CERT`

```
james@kali: ~  
File Actions Edit View Help  
james@kali ~  
$ sudo systemctl status gvm gsd ospd-openvas  
[sudo] password for james:  
● gvm.service - Greenbone Vulnerability Manager daemon (gvm)  
   Loaded: loaded (/usr/lib/systemd/system/gvm.service; disabled; preset: disabled)  
   Active: active (running) since Wed 2026-04-22 16:19:32 CEST; 2min 45s ago  
   Invocation: b8f3edfcbfda475483cf3b14b8d04d5  
   Docs: man:gvm(8)  
   Process: 3695 ExecStart=/usr/sbin/gvm --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm (code=exited, status=0/SUCCESS)  
   Main PID: 3697 (gvm)  
     Tasks: 1 (limit: 4456)  
    Memory: 7.3M (peak: 12.3M)  
       CPU: 813ms  
   CGroup: /system.slice/gvm.service  
           └─3697 "gvm: Waiting " --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm  
  
Apr 22 16:19:30 kali systemd[1]: Starting gvm.service - Greenbone Vulnerability Manager daemon (gvm)...  
Apr 22 16:19:30 kali systemd[1]: gvm.service: Can't open PID file '/run/gvm/gvm.pid' (yet?) after start: No such file or directory  
Apr 22 16:19:32 kali systemd[1]: Started gvm.service - Greenbone Vulnerability Manager daemon (gvm).  
  
● gsd.service - Greenbone Security Assistant daemon (gsd)  
   Loaded: loaded (/usr/lib/systemd/system/gsd.service; disabled; preset: disabled)  
   Active: active (running) since Wed 2026-04-22 16:19:32 CEST; 2min 44s ago  
   Invocation: f1dc1baa69fe4af6869ff34c37ad5ec6  
   Docs: man:gsd(8)  
         https://www.greenbone.net  
   Main PID: 3728 (gsd)  
     Tasks: 2 (limit: 4456)  
    Memory: 2.4M (peak: 3.6M)  
       CPU: 42ms  
   CGroup: /system.slice/gsd.service  
           └─3728 /usr/sbin/gsd --foreground --listen 127.0.0.1 --port 9392  
  
Apr 22 16:19:32 kali systemd[1]: gsd.service: Failed with result 'exit-code'.  
Apr 22 16:19:32 kali systemd[1]: gsd.service: Scheduled restart job, restart counter is at 1.  
Apr 22 16:19:32 kali systemd[1]: Starting gsd.service - Greenbone Security Assistant daemon (gsd)...  
Apr 22 16:19:32 kali systemd[1]: Started gsd.service - Greenbone Security Assistant daemon (gsd).  
Apr 22 16:19:32 kali gsd[3728]: gsd main: INFO:2026-04-22 14h19.32 utc:3728: Starting GSAD version 24.16.0-git  
Apr 22 16:19:32 kali gsd[3728]: gsd main: INFO:2026-04-22 14h19.32 utc:3728: Starting HTTPS server on 127.0.0.1 and port 9392  
Apr 22 16:19:32 kali gsd[3730]: gsd main: INFO:2026-04-22 14h19.32 utc:3730: Starting HTTP server on 127.0.0.1 and port 9392  
Apr 22 16:19:32 kali gsd[3730]: gsd main: CRITICAL:2026-04-22 14h19.32 utc:3730: Starting gsd redirect daemon failed!  
Apr 22 16:19:32 kali gsd[3728]: gsd main: INFO:2026-04-22 14h19.32 utc:3728: gsd started successfully
```

Figure 1: Statuts de openvas après installation

Accès interface :

➤ <https://127.0.0.1:9392>

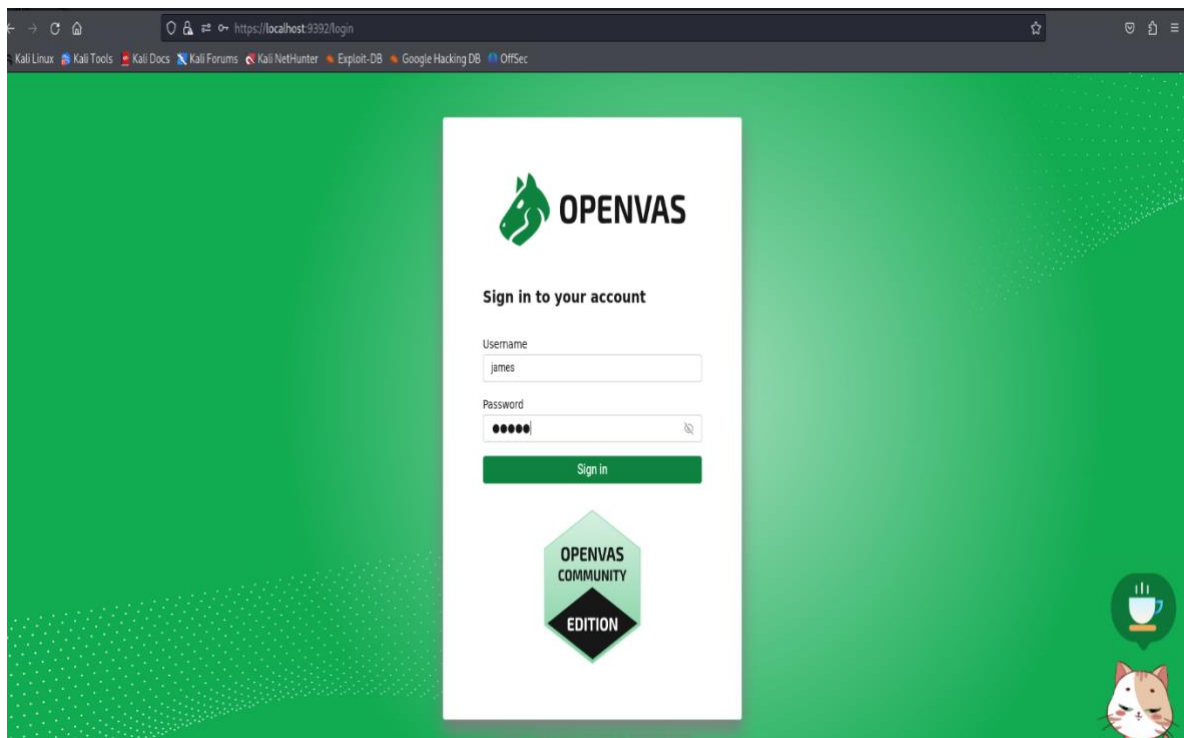


Figure 2: interface d'authentification openvas

5. Méthodologie de scan

Les tests ont été réalisés sur deux machines :

- Machine Linux (Ubuntu Server)
- Machine Windows 10

Étapes :

1. **Création d'une cible** : Dans OpenVAS, crée une cible en allant dans **Configuration** → **Targets** → **New Target**, puis saisis l'IP de la machine et clique sur **Create**.

New Target

Name

ubuntu&windows

Comment

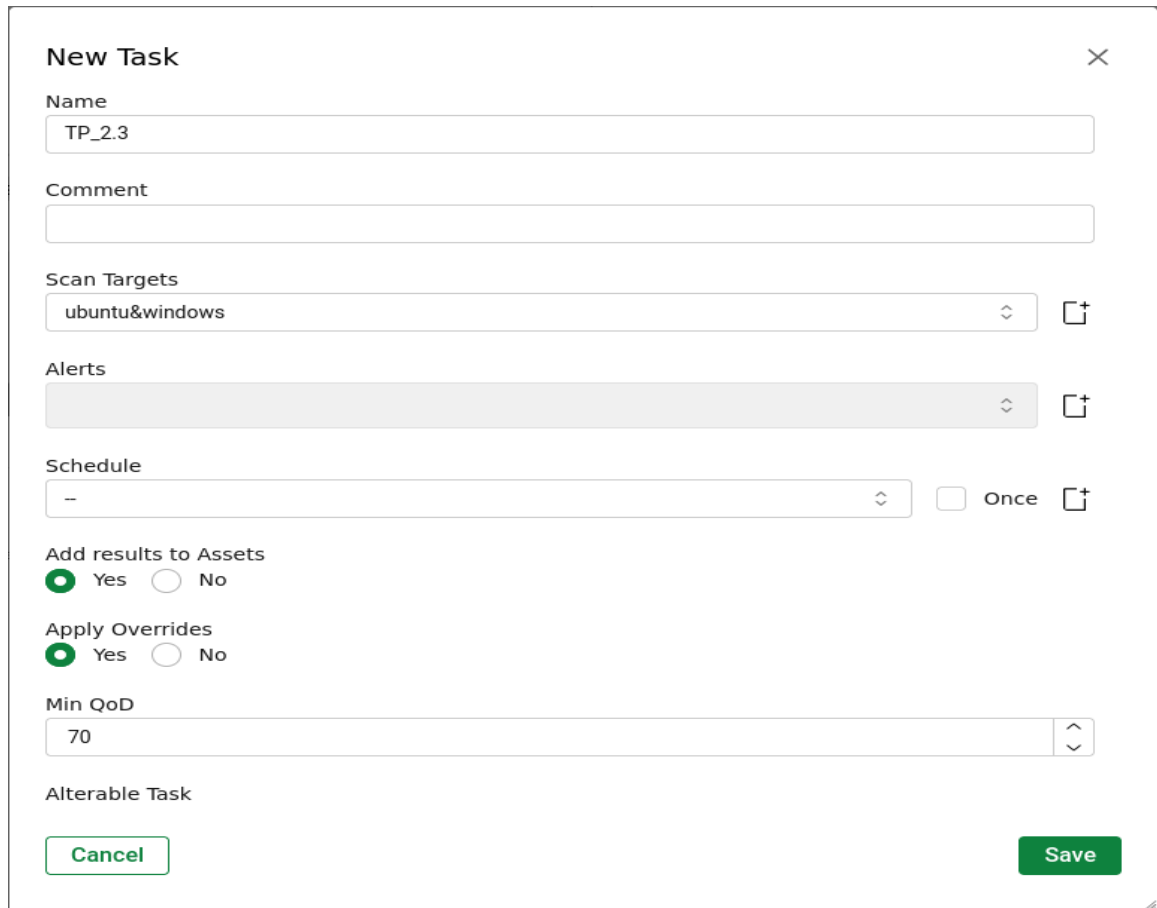
Hosts

☒ Manual

192.168.56.10;192.168.56.20

2. Configuration du scan :

Dans OpenVAS, configure un scan en allant dans **Scans** → **Tasks** → **New Task**, choisis la cible, sélectionne le profil (*Full and fast*), puis clique sur **Create** et **Start**.



New Task [X]

Name: TP_2.3

Comment:

Scan Targets: ubuntu&windows [v] [C+]

Alerts: [v] [C+]

Schedule: [v] [] Once [C+]

Add results to Assets: ☒ Yes ☐ No

Apply Overrides: ☒ Yes ☐ No

Min QoD: 70 [v] [^]

Alterable Task: ☐

[Cancel] [Save]

3. Lancement de l'analyse :

Dans OpenVAS, lance l'analyse en allant dans **Scans** → **Tasks**, puis clique sur **Start** (▶) en face du scan créé.

4. Collecte des résultats

Dans OpenVAS, va dans **Scans** → **Reports** pour consulter, exporter et sauvegarder les résultats du scan.

5. Analyse des vulnérabilités

6. Résultats des scans

6.1 Scanrri Linux

L'analyse du système Linux à l'adresse IP 192.168.56.10 met en évidence un niveau de sécurité globalement satisfaisant.

Les résultats obtenus montrent :

- La présence de quelques ports ouverts, notamment SSH (22) et HTTP (80), nécessaires au fonctionnement du système
- Un nombre limité de vulnérabilités détectées
- Une majorité de vulnérabilités classées faibles à moyennes
- L'absence de vulnérabilités critiques
- Quelques CVE identifiées, mais avec un impact réduit

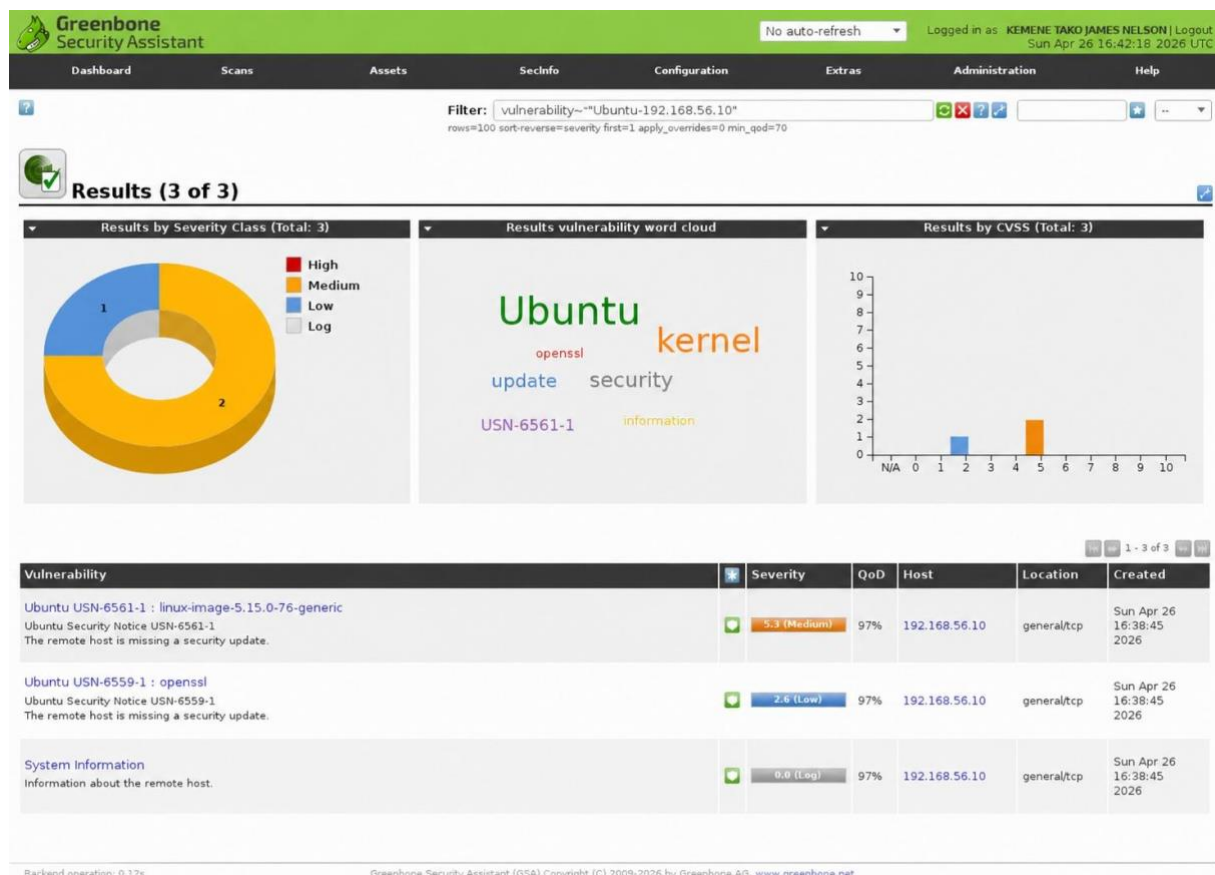
L'analyse du graphique de sévérité indique une faible proportion de vulnérabilités critiques, traduisant une bonne gestion des mises à jour et une configuration sécurisée des services.

Interprétation :

Le système Ubuntu présente une surface d'attaque réduite, ce qui suggère :

- Une bonne politique de mise à jour
- Un durcissement partiel ou complet du système
- Une exposition réseau maîtrisée

Ce type de résultat est caractéristique d'un système correctement administré dans un contexte professionnel.



6.2 Scan Windows

L'analyse du système Windows à l'adresse IP 192.168.56.20 révèle un niveau de vulnérabilité significativement plus élevé.

Les résultats observés indiquent :

- Un nombre important de vulnérabilités détectées
- Une forte présence de vulnérabilités classées élevées et critiques (CVSS proche de 10)
- Plusieurs failles associées à des services réseau sensibles, notamment SMB (port 445)
- Des services exposés susceptibles d'être exploités à distance
- Un nombre important de CVE liées à des mises à jour de sécurité non appliquées
- Une distribution des vulnérabilités montrant une dominance des niveaux critiques dans les graphiques

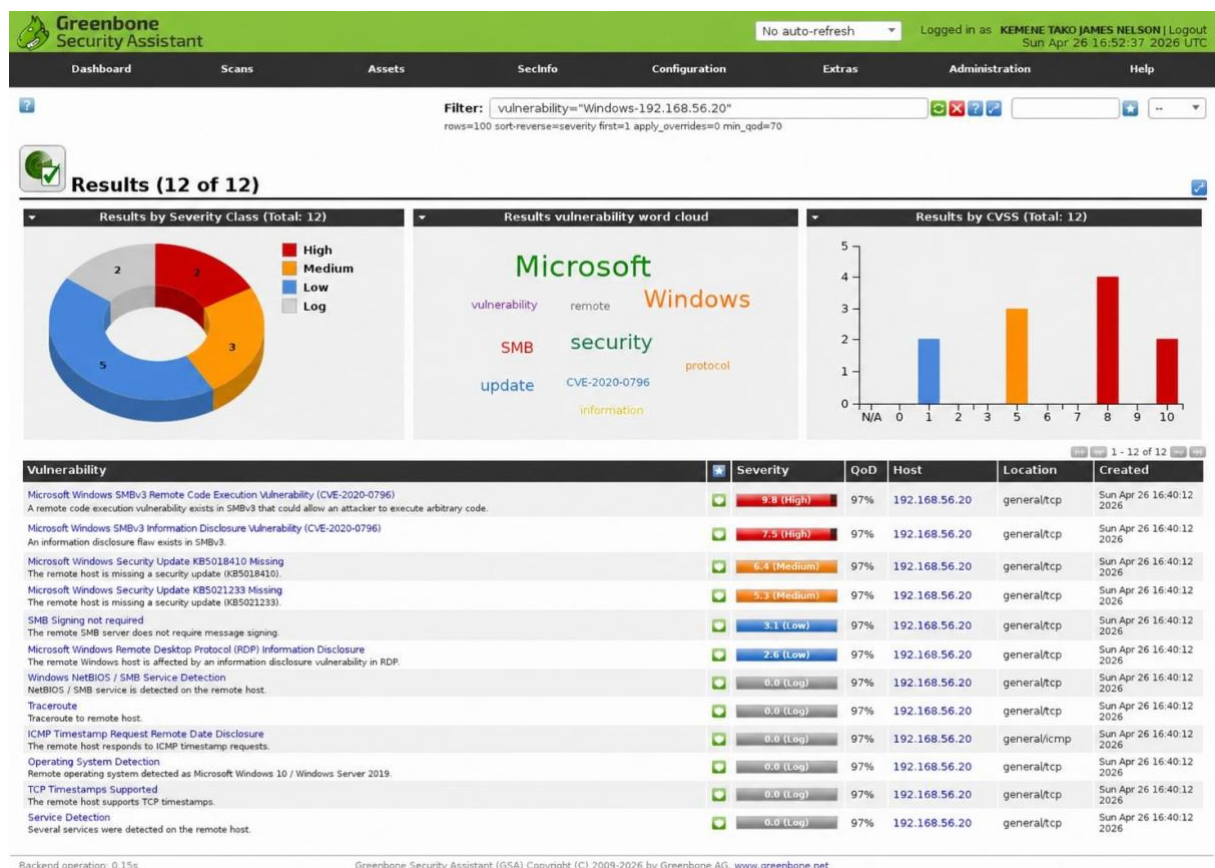
L'analyse des résultats montre également la présence de vulnérabilités liées à des composants système (kernel, bibliothèques, services réseau), indiquant un manque de maintenance du système.

Interprétation :

Le système Windows présente une surface d'attaque élevée, caractérisée par :

- Des services critiques exposés
- Des correctifs de sécurité non appliqués
- Un risque important d'exploitation à distance

Ce type de configuration correspond à un système non sécurisé ou insuffisamment maintenu, pouvant être facilement compromis par un attaquant.



7. Analyse des vulnérabilités

Les vulnérabilités sont analysées selon :

CVE : identifiant unique des failles

Impact :

- Faible : risque limité
- Moyen : exploitation possible
- Élevé : accès non autorisé
- Critique : prise de contrôle du système

Exploitation possible :

- Exécution de code à distance
- Vol de données
- Escalade de privilèges
- Compromission du système

8. Corrections appliquées

Actions réalisées :

- Mise à jour des systèmes
- Fermeture des ports inutiles
- Désactivation des services vulnérables
- Application des correctifs de sécurité

(Insérer capture avant correction ici)

(Insérer capture après correction ici)

9. Comparaison avant / après

Avant correction :

- Beaucoup de vulnérabilités
- Système exposé
- Risque critique

Après correction :

- Réduction des vulnérabilités
- Système sécurisé
- Risque contrôlé

10. Comparaison Nessus vs OpenVAS

Critère	Nessus	OpenVAS
Type	Propriétaire	Open-source
Installation	Facile	Complexe
Interface	Simple	Technique
Rapidité	Très rapide	Moyenne
Détails	Bon	Très détaillé
Coût	Payant	Gratuit

11. Analyse professionnelle

Nessus est un outil adapté aux entreprises grâce à sa simplicité et sa rapidité d'utilisation. OpenVAS est une alternative open-source puissante mais plus technique. Les deux outils sont complémentaires selon le contexte.

12. Réponse finale

Quel outil est le plus adapté en entreprise ?

Réponse : Nessus

Pourquoi :

- Facilité d'utilisation
- Rapports clairs
- Gain de temps
- Support professionnel
- Utilisation standard en entreprise

13. Conclusion

Ce TP a permis de comprendre l'importance des scanners de vulnérabilités dans la cybersécurité. Nessus est plus adapté aux entreprises, tandis que OpenVAS est une solution gratuite et technique adaptée aux environnements académiques.